

Multi-Standard Migration Playbook for NBFCs

Companion to the SOC 2 and PCI v4 NBFC playbooks. Consolidates SOC 2, PCI DSS v4, DPDP Act 2023, ISO 27001:2022, and NIST CSF 2.0 into a single tagged control spine, shared evidence bank, and unified cadence calendar for an NBFC CISO office.

Scope

NBFC HFCs, digital lenders, and payment-aggregator-adjacent NBFCs who face concurrent AICPA SOC 2 (B2B fintech customers), VISA/MC PCI v4 (acquirer obligation), DPDP (every digital customer / employee record), ISO 27001 (group / parent mandate), and NIST CSF 2.0 (cloud partner or FedRAMP-aligned SaaS expectation).

1. Why consolidate five standards into one spine

Each standard was conceived for a different audience: SOC 2 is for the B2B SaaS customer; PCI DSS for card networks; DPDP Act 2023 for the citizen; ISO 27001 for the auditor; NIST CSF 2.0 for the operator. The controls overlap heavily, but the *fragments* don't. Two 'encryption at rest' controls differ on key length (PCI 256-bit, SOC 2 reasonable), on rotation (DPDP purpose-bound), on HSM (PCI mandate), and on scope (NIST covers mobile, ISO excludes OT). Unifying prevents the NBFC from running four parallel control inventories and producing four parallel evidence packs.

Standard	Primary audience	Cadence	NBFC trigger
SOC 2 (TSC 2017, 2022)	B2B fintech customers	Annual + bridge	Fintech partner contractual clause
PCI DSS v4.0 / v4.0.1	Card networks / acquirer	Annual ROC + ASV	Merchant-aggregator licence or acquirer rule
DPDP Act 2023 + Rules 2025	Data Principal (citizen)	On breach	Any digital NBFC handling personal data
ISO 27001:2022 + 27002:2022	Certification auditor	Triennial + surveillances	Group mandate or overseas client ask
NIST CSF 2.0 (2024)	Operator / framework	Continuous maturity	Cloud partner alignment, board cyber maturity report

2. Tag taxonomy (the 'unified spine')

Every control in Section 9 of the workbook is tagged exactly one way. Tags drive evidence reuse, cadence assignment, and which external assessor touches it.

Tag	Definition	Evidence reuse	Owner cadence
UNIVERSAL	Identical text across >=4 standards; one test satisfies all.	Single evidence file annotated with all standard IDs.	Annual unified test, rolled forward as bridge letter to all.
MOSTLY-SHARED	Core requirement matches; small deltas in scope or threshold.	One evidence file + per-standard delta sheet.	Annual unified test + delta walkthrough for each delta.
STANDARD-SPECIFIC	Only one standard requires it, but it touches shared infrastructure.	Owner produces under master evidence; cited only by the standard.	Cadence driven by the single standard.
DIFFERENTIATED	Each standard defines a different control for the same risk.	Separate evidence per standard; cross-mapped for the CISO.	Per-standard cadence; never consolidate into one test.

Rule of thumb: if a SOC 2 control text could literally 'slot into' an ISO 27001 Annex A control with no caveats, it is at least MOSTLY-SHARED. If the ISO Annex A control has a 'control attribute' (preventive/detective, manual/automatic, physical/informational) not in SOC 2, it becomes DIFFERENTIATED.

3. Cross-tag YAML scheme (config-as-code)

Every control gets a YAML block. The CISO's evidence-bank ingests these blocks, and the unified control matrix (UCM) maps them per standard. Example:

```
control: C-012 # Encryption of personal data at rest
domain: data-protection
class: technical
tag: MOSTLY-SHARED
statement: >
  All NBFC systems store personal and cardholder data using AES-256 (or stronger),
  with keys held in FIPS 140-2 L3 HSM for cardholder data and KMS for personal data.
standards:
SOC2: CC6.1 + CC6.7
PCI: 3.5.1, 3.6.1, 4.1
DPDP: Sec.8(4) + Rule7(2)
ISO27001: A.8.24
NIST-CSF: PR.DS-1
evidence:
- KMS rotation logs (quarterly)
- HSM attestation report (annual)
- PCI key-custodian sign-off (annual)
cadence: ANNUAL-BRIDGE
owner: ciso@nbfc.in
test:
method: SAMPLING
sample_size: 25 systems, 50 keys
sampling: MONETARY
```

Practical effect: SOC 2 and PCI auditors pull the same attestation report; ISO Stage 1 auditor pulls the same report plus the control-attribute sheet; DPDP investigation pulls the same report plus the data-principal purpose statement.

4. Multi-cadence calendar (NBFC roll-forward)

Indian financial year is April-April. Audits cluster around Feb-Mar and Sep-Oct. Build a 24-month rolling calendar with one bridge cycle that covers all five.

Quarter	Window	Primary deliverable	Standards touched	Owner
Q1 (Jan-Mar)	Peak audit window	SOC 2 Type II scope-period close, ISO 27001 surveillance R1, RBI IS Act close	SOC 2, ISO 27001, RBI	CISO + Internal Audit
Q2 (Apr-Jun)	FY25-26 close-out	DPDP internal readiness, NIST CSF maturity re-baseline, FRA / IS Audit DPDP initiation	DPDP, NIST CSF, RBI	DPO + CISO
Q3 (Jul-Sep)	Pre-RBI audit prep	RBI IS audit prep, ISO 27001 Stage 2 readiness, PCI v4 design evidence finalise	RBI, ISO, PCI	CISO + IT
Q4 (Oct-Dec)	Card-network + DPDP window	PCI ROC period close (Oct 31), DPDP DPIA submission, SOC 2 bridge period	PCI, DPDP, SOC 2	QSA-led + CISO
Ad-hoc	Continuous	Cert-IN 6h notification, RBI 2h cyber incident, DPDP 72h breach to Board	All PCI 24h acquirer notify	IR Lead + Legal

5. The five clocks that bite the NBFC

A single data breach can trigger five different notification clocks. They do not pause each other. The CISO's job is to know which one fires first and pre-write the notification letter.

Clock	Trigger	Window	Recipient	Authority
Cert-IN Rule 4(1) 2013	Any cyber incident (incl. attempt)	6 hours	Cert-IN + sectoral CERT	MeiTY
RBI Cyber Security Framework 2024	Cyber-incident at NBFC	2 hours (initial) + 24h root-cause update	RBI D-SIG / DoS + HO cyber cell	RBI
DPDP Sec.8(6) 2023 + Rule 7(2) 2025	Personal-data breach causing harm	72 hours	Data Protection Board India	MEITY / DPB
Acquirer / Network rule (PCI / VISA / MCO)	CCDE compromise or card-data exfil	24 hours brand / cardholder / acquirer	Acquirer bank + card networks	PCI SSC + acquirer
SOC 2 customer contract	Customer-data material finding	Per contract (typ. 24-72h)	Subscribing fintech customers	Contract / counsel

NBFC trap question (interview-style): A 'loan-application' API on AWS leaks 600k Aadhaar numbers. Cert-IN requires 6h. RBI requires 2h. DPDP requires 72h. PCI applies only to card data (DPDP applies to all personal data). SOC 2 customers must be notified per contract. Answer: Cert-IN first (6h), RBI initial within 2h, DPDP to DPB within 72h, fintech customers per contract. SOC 2 has no clock.

6. Migration playbook - 12-week minimum

Week 1-2 - Inventory & map

Pull 5 control inventories; build UCM with tag column; freeze scope rows.

Week 3-4 - Crown-jewel & DPIA fusion

Run DPIA (DPDP) and crown-jewel assessment (PCI / SOC 2). Reconcile subsystems.

Week 5-6 - Policy rewrite (single source)

Rewrite Acceptable Use, Encryption, IR, Vendor, Access into one master; append standards matrix.

Week 7-8 - Evidence-bank rebuild

Move artefacts into Evidence Catalog (sheet 12) with YAML pointers; tag by Control ID.

Week 9-10 - Unified testing

Run plan-of-test; produce UNIVERSE-test pack; per-standard deviations become delta sheets.

Week 11-12 - Readiness & dry-run

Internal mock-audit; remediation; plan year-end cadence per Section 4.

7. Crosswalk highlights - the five "deltas" worth memorising

Five controls that look identical but differ in material ways. Boards ask about these.

Risk	Caught by	Co-located in workbook
Encryption key rotation	PCI 3.6.5 = annual min; SOC 2 = per policy; DPDP = purpose-bound; ISO A.8.24 = per risk; NIST PR.DS-2 = no period.	C-012 - MOSTLY-SHARED
Incident notification	CERT-IN 6h; RBI 2h; DPDP 72h; PCI acquirer 24h; SOC 2 customer contract 24-72h.	C-077 - DIFFERENTIATED
Vendor due diligence	SOC 2 = carve-out via subservice report; PCI 12.8 = current list + annual attestation; DPDP = DPF agreement; ISO A.5.19-23 = supplier control system + supply chain risk.	C-061 - MOSTLY-SHARED
Access reviews	SOC 2 = quarterly privileged; PCI 7.3 = every 6m; DPDP = only on request; ISO A.5.18 = per risk; NIST PR.AC-4 = annual.	C-019 - DIFFERENTIATED
Data deletion / retention	SOC 2 = per policy; PCI = transaction + 1y; DPDP = right to erase + purpose; ISO A.5.34 = PII; NIST PR.IP-6 = data lifecycle.	C-039 - DIFFERENTIATED

8. Interview Q&A; - fresher to expert

Q1. Why is SOC 2 not a "standard" like ISO 27001?

SOC 2 is a *report* on controls against Trust Services Criteria; it is not a managed certificate framework. ISO 27001 is a managed cert (Stage 1, 2, surveillance, recert every 3y). A SOC 2 Type II is a 12-month attestation by a CPA firm.

Q2. Why is PCI v4 special vs SOC 2 + ISO?

PCI is contractual (you signed with the acquirer); SOC 2 / ISO are voluntary. PCI has a defined cardholder-data environment (CDE) scope and Qualified Security Assessors (QSA). Fail the PCI ROC = lose merchant-aggregator licence.

Q3. When does the DPDP Act actually apply to NBFC?

Whenever the NBFC processes 'personal data' (any digital identifier of a natural person) - which is essentially always for a digital lender. Consent, purpose limitation, data principal rights, breach notification, DPF agreement, DPO appointment over a threshold all apply.

Q4. Why is ISO 27001 more paperwork than NIST CSF?

ISO 27001 is auditable (you either pass or fail); NIST CSF 2.0 is a maturity framework (Tier 1-4 across Govern/Identify/Protect/Detect/Respond/Recover). ISO requires Statements of Applicability; NIST requires a current profile + target profile.

Q5. Can one firm do SOC 2 + PCI + ISO?

A Big-4 firm can, but independence rules of PCI (QSA separation) and SOC 2 (CPA license) typically mean SOC 2 + ISO are bundled and PCI is separate. Many NBFC RFPs award a single Integrated Audit Firm for SOC 2 + ISO + NIST, and a separate QSA firm for PCI - see the RFP kit playbook.

Q6. How does the NBFC scale this without doubling headcount?

Tag-based reuse: UNIVERSAL controls have one test, one evidence item, one owner. MOSTLY-SHARED controls share 80%. Only DIFFERENTIATED controls run separate audits. Target: 60% UNIVERSAL or MOSTLY-SHARED, 40% DIFFERENTIATED.

Q7. What's the single most common NBFC mistake?

Running SOC 2 + PCI in parallel from day one with two vendors producing overlapping evidence. Run a 6-week evidence-bank rebuild *before* the Type II period opens; share with both vendors; cut audit cost ~30%.

Q8. What's the new DPDP fine risk vs SOC 2 Type II?

DPDP Sec.33: up to 250 Cr for failure to take reasonable security. SOC 2 Type II is reputational, not fined. Boards care about DPDP fine exposure more than SOC 2 - prioritise DPIA + DPF contracts accordingly.

Q9. Does RBI mandate ISO 27001?

RBI's master circular on IS audit and cyber resilience require 'best practice' frameworks - ISO 27001 is the de facto default. RBI does not require the cert but acquirer banks and fintech partners commonly do.

Q10. NIST CSF 2.0 vs ISO 27001 - when to use which?

NIST CSF 2.0 for ongoing maturity tracking (Tier 1-4 visible to the board). ISO 27001 for the external cert that closes enterprise deals. They map cleanly: Govern / Identify / Protect align to ISO Clause 5-8 + Annex A controls.

9. Glossary - 30 terms NBFC CISOs must know

Term	Meaning
AICPA	American Institute of CPAs - publishes SOC 2 TSCs
ASV	Approved Scanning Vendor (PCI) - quarterly external scan
CDE	Cardholder Data Environment (PCI in-scope system set)
CISO	Chief Information Security Officer
CERT-In	Indian Computer Emergency Response Team - 6h rule
DPB	Data Protection Board India (DPDP enforcement)
DPF	Data Processing / Data Fiduciary (DPDP)
DPIA	Data Protection Impact Assessment (DPDP)
DPDP	Digital Personal Data Protection Act 2023
DP	Data Principal - the natural person (DPDP)
FRA	Financial Reporting Audit
HFC	Housing Finance Company (NBFC sub-type)
HSM	Hardware Security Module (PCI min FIPS 140-2 L3)
IS Audit	Information Systems Audit (RBI-mandated annual)
KMS	Key Management Service (cloud-native key store)
NBFC	Non-Banking Financial Company (RBI regulated)
NIST CSF	National Institute of Standards - Cybersecurity Framework
PCI DSS	Payment Card Industry Data Security Standard v4.0 / v4.0.1
PII	Personally Identifiable Information
QSA	Qualified Security Assessor (PCI)
RBI	Reserve Bank of India
ROC	Report on Compliance (PCI annual deliverable)
ROPA	Record of Processing Activities (DPDP)
SOC 2	Service Organization Control 2 (AICPA)
SoA	Statement of Applicability (ISO 27001)
TSC	Trust Services Criteria (SOC 2: CC + A + C + PI + P)

TRA	Targeted Risk Analysis (PCI v4 mandate)
TSCF	Trust Services Criteria - 2017 with 2022 points of focus
UCM	Unified Control Matrix (this playbook's output)
YAML	YAML Ain't Markup Language - config-as-code (this playbook)

10. Case study - mid-size NBFC HFC

Mid-size NBFC HFC, 2.4 Cr customers, 1,800 employees, AWS-hosted LOS, payment aggregator for disbursal. Pre-consolidation: 4 vendors; 5 control inventories; 18-month elapsed SOC 2 + PCI evidenced twice; CERT-IN 6h drill never run.

Pre-consolidation state

Metric	Before
Audit vendors	4
Audit days/year	220
Evidence artefacts	1,800+
Control overlap identified	<30%
Board IS report	50 pages, manual

12-week consolidation output

Metric	Before	After
Audit vendors	4	2 (IA + QSA split)
Audit days/year	220	150
Evidence artefacts (unique)	1,800+	420
UCM coverage UNIVERSE	-	62%
Board IS report cycle	8 weeks manual	Auto from UCM

Outcome: ~32% audit-cost reduction; SOC 2 + PCI ROC passed clean; DPDP DPIA in place; RBI IS Audit + Cert-IN 6h drill completed. Board cyber maturity moved from Tier 2 to Tier 3 (NIST CSF).